SRI LANKA INSTITUTE OF INFORMATION TECHNOLOGY

FACULTY OF COMPUTING.

WEB SECURITY- IE2062

IT22121592 – HERATH H.M.C.H.K

Y2S2

Contents

Subdomain Enumeration: 3
Vulnerability title. 4
Vulnerability description. 4
Affected components. 5
Impact assessment. 6
Steps to reproduce: 7
Proposed mitigation or fix 8

The subdomain shop.bigcommerce.com

Subdomain Enumeration:

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ nslookup shop.bigcommerce.com 8.8.8.8
Server:         8.8.8.8
Address:        8.8.8.8#53

Non-authoritative answer:
shop.bigcommerce.com    canonical name = store-vke3dp31fl.mybigcommerce.com.
Name:   store-vke3dp31fl.mybigcommerce.com
Address: 192.200.160.23
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ dig shop.bigcommerce.com @8.8.8.8

; <<>> DiG 9.19.21-1-Debian <<>> shop.bigcommerce.com @8.8.8.8
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 16238
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;shop.bigcommerce.com.          IN      A

;; ANSWER SECTION:
shop.bigcommerce.com.   900     IN      CNAME   store-vke3dp31fl.mybigcommerce.com.
store-vke3dp31fl.mybigcommerce.com. 883 IN A    192.200.160.23

;; Query time: 404 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Oct 18 15:35:17 +0530 2024
;; MSG SIZE  rcvd: 110
```

Vulnerability title.

404 not found.

Missing X frame.

Vulnerability description.

404 not found.

When you see the "404 Not Found" message, on a website it means that the server couldn't find what you were looking for at that moment; it's not really a security issue on its own. If it's not handled properly it could lead to some security problems down the line. If the custom 404 page gives away information, about the server how the application is structured, or what

technologies are being used underneath all of that can make it easier for attackers to find ways to get in. If there are many 404 errors happening regularly it could be a sign that things aren't configured properly which might make it easier for someone to mess with or even shut down parts of the website.

Missing X frame options header.

When a website doesn't include the X frame options HTTP header, in its responses it's vulnerable to the Missing X frame options Header flaw. This header is essential for thwarting clickjacking attacks, where hackers can insert a page into an iframe to deceive users into engaging with it. If this header is absent attackers can alter the user's interaction. Possibly obtain access, to important operations. To reduce this weakness, in security measures for web applications, it is recommended that the X frame options header be incorporated with settings, like DENNY or SAMEORIGIN, or use the Content Security Policy header with the frame-ancestors directive for added security measures.

Affected components.

404 not found:

- Misconfigurations in web server setups can cause issues, with how URLs or paths are handled.
- Application logic refers to the routing or backend processes that struggle to handle the availability of resources.
- Custom Error Pages Implementation, for website 404 errors with the potential for revealing details such, as stack traces or database information.
- Ensure that any files or directories, with information are protected to prevent access and avoid unintentional error messages, like 404s.

Missing X frame options header.

- Web Application Frameworks are platforms that may not have built-in security headers turned on automatically (for example some versions of Django or Ruby, on Rails).
- HTTP response setup issues occur when the server or application settings are not properly configured to include the Xframe options header in their responses.
- Content Management Systems (CMS); CMS platforms may not automatically establish this header feature which can expose websites to vulnerabilities.
- Web interfaces that don't include security headers when accessing web pages or UI elements via APIs.
- When static files such, as HTML or JavaScript are served without the headers in place there's a risk of clickjacking if they can be framed within a webpage.

Impact assessment.

404 not found:

- If a customized error page displays details such, as server paths or error messages to intruders who are conducting reconnaissance activities, they may use this information, for attacks.
- Experiencing frequent or mishandled 404 errors can create a user experience that may lead to a loss of trust and possibly result in reduced traffic and revenue.
- An attacker could overwhelm the server with several requests, to endpoints that don't exist in what's known as a Denial of Service attack This action can deplete server resources and disrupt the experience, for genuine users.
- Misconfigured Endpoints Issue Explanation: A 404 error could signal problems with configured or vulnerable endpoints that might be at risk of exploitation if they mistakenly reveal their functions or data.
- Frequent 404 errors can harm a company's reputation and undermine consumer trust in its brand by giving the impression that the website is unreliable or poorly managed.

Missing X frame options header.

- Users may fall victim to clickjacking attacks when the X frame options header is absent as it can deceive them into clicking on concealed elements that result in activities, like modifying account settings or conducting transactions.
- Unauthorized access to data, is a concern as malicious individuals could potentially take advantage of this loophole to obtain information such, as login credentials or financial data using deceptive overlays.
- Trust Among Users: In case users encounter clickbait or other security concerns, within the app their trust could diminish, resulting in interaction and possible financial repercussions.
- Failure to put security measures in place like using the X Frames Options header can cause violations of regulations such, as GDPR or PCI DSS which may lead to consequences or penalties.
- Security vulnerabilities can have an impact on a company's reputation by causing breaches that may result in the loss of customers and a decrease, in market standing.

Steps to reproduce:

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ nslookup shop.bigcommerce.com 8.8.8.8
Server:         8.8.8.8
Address:        8.8.8.8#53

Non-authoritative answer:
shop.bigcommerce.com    canonical name = store-vke3dp31fl.mybigcommerce.com.
Name:   store-vke3dp31fl.mybigcommerce.com
Address: 192.200.160.23
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ dig shop.bigcommerce.com @8.8.8.8

; <<>> DiG 9.19.21-1-Debian <<>> shop.bigcommerce.com @8.8.8.8
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 16238
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;shop.bigcommerce.com.          IN      A

;; ANSWER SECTION:
shop.bigcommerce.com.   900     IN      CNAME   store-vke3dp31fl.mybigcommerce.com.
store-vke3dp31fl.mybigcommerce.com. 883 IN A    192.200.160.23

;; Query time: 404 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Oct 18 15:35:17 +0530 2024
;; MSG SIZE  rcvd: 110
```

Proposed mitigation or fix

404 not found:

1. Creating personalized 404 error pages:

Create 404 error pages that are easy for users to navigate and do not reveal any confidential details regarding the server or application layout.

Please refrain from showing error details, like stack traces or specific paths that might assist attackers.

2. Errors handling:

Make sure to incorporate error management in your program to handle any requests effectively and securely while also logging them without revealing sensitive details.

Employ an approach, to managing errors to ensure uniform feedback is provided.

3. Monitoring and logging:

Make sure to keep an eye on and record any 404 errors to spot trends that could point to configured endpoints or possible attack routes.

Examine the logs to look for any patterns that might indicate hackers are trying to probe or enumerate information.

4. SEO consideration.

Make sure to follow SEO guidelines, for 404 pages by ensuring they display the HTTP status code (404) letting search engines know that the page is not available.

Please include links, to the website's homepage or other related pages to assist users in navigating from the error message.

5. Managing resources:

Remember to check and maintain the resources featured on your website to guarantee that all URLs are current and any outdated links are promptly removed.

Missing X-Frame-Options Header

1. Add the Xframe options header to your implementation.

Make sure to set up your web server settings so that the X frame options header is included in every HTTP response you send out with the suggested values being:

- DENY.
- SAMEORIGIN
- ALLOW-FROM uri

2. Make sure to implement a Content Security Policy (also known as CSP) for added security.

You should set up the Content Security Policy header with the frame ancestors directive to have control, over it in a manner. Example:

```
.Content-Security-Policy: frame-ancestors 'self';
```

This approach offers flexibility and can be employed in conjunction, with the X Frames Options header to enhance security measures.

3. Review third-party content:

Review any content, like widgets or ads that might be included in your app to make sure they don't pose a click-hijacking threat, to your website.

4. Testing and validation:

Make sure to check your web application to confirm that the X. Frame. The options header is included in the responses. Utilize tools, like web application security scanners or browser developer tools.

Ensure security checks are conducted to confirm that no unauthorized pages can be accessed through framing techniques.

5. Educate the development teams.

Make sure to offer guidance and support to development teams regarding the significance of incorporating security headers such, as XFrameOptions and emphasize the risks associated with overlooking them.